

Laporan Keamanan Informasi

Threat Modeling dan Analisis Risiko

Sistem TUMBUH

AAA Security, Data Protection, dan Non-Repudiation

Anggota Kelompok	Ghiffari Bravia Hisham - G6401231050 Adam Naufal - G6401231082 Rafif Muhammad Farras - G6401231102
Mata Kuliah	KOM1315 Keamanan Informasi
Sistem	TUMBUH - Career & Internship Tracker

Threat Modeling dan Analisis Risiko

1. Tujuan Dokumen

Dokumen ini memetakan ancaman keamanan terhadap sistem TUMBUH pada kondisi awal, yaitu sistem yang diasumsikan belum memiliki kontrol keamanan seperti JWT authentication, role-based authorization, accounting/audit logging, password hashing yang kuat, enkripsi data sensitif, dan digital signature.

Hasil threat modeling digunakan untuk menurunkan kebutuhan keamanan yang akan diimplementasikan pada tahap berikutnya.

2. Ruang Lingkup

Threat modeling mencakup:

- Proses login dan pengelolaan akun.
- Pengelolaan profil mahasiswa.
- Pengelolaan data perusahaan dan lowongan oleh HR.
- Proses lamaran mahasiswa.
- Perubahan status lamaran oleh HR.
- Aktivitas admin platform.
- Penyimpanan data sensitif dan dokumen pengguna.
- Log aktivitas dan bukti audit.

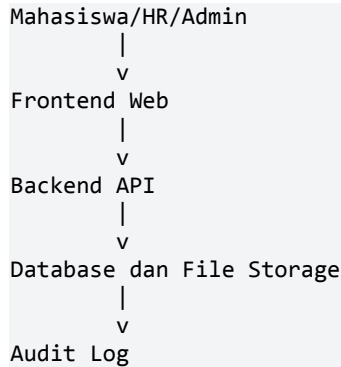
Threat modeling tidak mencakup:

- Keamanan fisik server.

- Serangan terhadap perangkat pribadi pengguna.
- Audit keamanan pihak ketiga.
- Integrasi SSO institusi secara penuh.

3. Data Flow Overview

Alur data utama TUMBUH:



Titik yang perlu diamankan:

1. Komunikasi pengguna dengan frontend.
2. Request dari frontend ke backend.
3. Validasi identitas dan hak akses pada backend.
4. Penyimpanan data pada database.
5. Penyimpanan dokumen seperti CV.
6. Pencatatan aktivitas penting pada audit log.

4. Identifikasi Threat Actor

Threat actor	Motivasi	Contoh ancaman
Pengguna tidak terautentikasi	Mengakses data tanpa akun	mencoba endpoint langsung, brute force login
Mahasiswa berbahaya	Mengakses data mahasiswa lain atau memanipulasi lamaran	mengganti ID pada request
HR berbahaya	Mengakses data pelamar di luar perusahaannya	melihat lamaran perusahaan lain
Admin terkompromi	Menyalahgunakan akses luas	mengubah data pengguna atau lowongan
Penyerang eksternal	Mencuri data atau mengambil alih akun	credential stuffing, token theft, SQL injection
Anggota tim yang lalai	Membocorkan secret atau konfigurasi	commit .env, private key, atau database password

5. STRIDE Threat Analysis

5.1 Spoofing

Spoofing terjadi ketika penyerang berpura-pura menjadi pengguna lain.

Ancaman	Dampak	Mitigasi
Login tanpa validasi kredensial yang kuat	Akun pengguna dapat diambil alih	password hashing, rate limiting, validasi login
Token mudah dipalsukan	Penyerang dapat mengakses endpoint protected	JWT signed token, expiration, secret management
HR palsu mendaftar sebagai perusahaan	Lowongan palsu dapat dipublikasikan	verifikasi perusahaan oleh admin

5.2 Tampering

Tampering terjadi ketika data diubah tanpa izin.

Ancaman	Dampak	Mitigasi
Mahasiswa mengubah status lamaran sendiri	Integritas proses seleksi rusak	RBAC dan ownership check
HR mengubah lowongan perusahaan lain	Data perusahaan lain rusak	company ownership validation
Request API dimodifikasi untuk mengubah user ID	Akses horizontal tidak sah	backend authorization pada setiap endpoint
Data penting diubah tanpa bukti	Sulit dibuktikan siapa pelaku perubahan	audit logging dan digital signature

5.3 Repudiation

Repudiation terjadi ketika pengguna menyangkal aktivitas yang pernah dilakukan.

Ancaman	Dampak	Mitigasi
HR menyangkal telah mengubah status lamaran	Konflik dan kehilangan akuntabilitas	audit log perubahan status
Admin menyangkal penghapusan data	Investigasi insiden sulit dilakukan	admin activity log
Transaksi penting tidak memiliki tanda tangan	Non-repudiation lemah	digital signature untuk aksi penting

5.4 Information Disclosure

Information disclosure terjadi ketika data sensitif bocor kepada pihak yang tidak berhak.

Ancaman	Dampak	Mitigasi
CV mahasiswa dapat diakses publik	Kebocoran data pribadi	authorization check dan protected file access
Data profil mahasiswa dilihat HR yang tidak relevan	Pelanggaran privasi	pembatasan akses berbasis relasi lamaran
Password tersimpan tidak aman	Kompromi banyak akun	hashing dan salting
Secret key masuk ke repositori	Token atau enkripsi dapat dikompromikan	.gitignore, environment variable, secret rotation

5.5 Denial of Service

Denial of Service terjadi ketika layanan dibuat tidak tersedia.

Ancaman	Dampak	Mitigasi
Brute force login berulang	Server terbebani dan akun ditargetkan	rate limiting dan lockout strategy
Upload file sangat besar	Storage atau bandwidth habis	validasi ukuran dan tipe file
Request API masif	Backend tidak responsif	throttling dan monitoring

5.6 Elevation of Privilege

Elevation of privilege terjadi ketika pengguna memperoleh hak akses lebih tinggi dari seharusnya.

Ancaman	Dampak	Mitigasi
Mahasiswa mengakses endpoint HR	Manipulasi lowongan atau data perusahaan	RBAC di backend
HR mengakses fitur admin	Pengambilalihan fungsi platform	permission check per endpoint
Role diubah melalui request client	Pengguna meningkatkan hak akses sendiri	role hanya diatur backend/admin

6. Risk Matrix

Skala:

- Likelihood: Low, Medium, High
- Impact: Low, Medium, High
- Risk level: Low, Medium, High, Critical

ID	Risiko	Likelihood	Impact	Level	Mitigasi prioritas
R1	Akun diambil alih karena authentication lemah	High	High	Critical	password hashing, JWT, rate limiting
R2	Mahasiswa mengakses data mahasiswa lain	Medium	High	High	ownership check dan RBAC
R3	HR melihat lamaran perusahaan lain	Medium	High	High	company-scoped authorization
R4	Status lamaran dimanipulasi	Medium	High	High	role validation, audit log, digital signature
R5	Password bocor dari database	Medium	High	High	hashing dan salting
R6	CV atau profil mahasiswa bocor	Medium	High	High	protected file access dan enkripsi
R7	Aktivitas admin tidak terlacak	Medium	Medium	Medium	accounting/audit logging
R8	Secret key dikomit ke repositori	Medium	High	High	.gitignore, env config, secret rotation
R9	Brute force login	High	Medium	High	rate limiting dan monitoring
R10	Pengguna menyangkal perubahan data penting	Medium	Medium	Medium	digital signature dan audit trail

7. Security Requirement Analysis

Berdasarkan ancaman di atas, kebutuhan keamanan TUMBUH adalah:

7.1 Authentication Requirements

- Sistem harus memverifikasi identitas pengguna sebelum mengakses fitur protected.
- Password harus disimpan menggunakan hashing dan salting.
- Token autentikasi harus memiliki tanda tangan, masa berlaku, dan validasi server-side.
- Login gagal harus dicatat dan dibatasi untuk mencegah brute force.

7.2 Authorization Requirements

- Sistem harus menerapkan role-based access control untuk `student`, `hr`, dan `admin`.
- Sistem harus melakukan ownership check untuk data profil, lamaran, lowongan, dan perusahaan.
- Role dan permission tidak boleh ditentukan dari input client tanpa validasi backend.
- Endpoint sensitif harus menolak akses yang tidak sesuai dengan role.

7.3 Accounting Requirements

- Sistem harus mencatat aktivitas penting pengguna.
- Log harus mencatat actor, action, resource, timestamp, status, dan detail yang aman.
- Log harus membantu investigasi tanpa membocorkan password, token, atau private key.
- Aktivitas admin dan perubahan status lamaran harus menjadi prioritas pencatatan.

7.4 Data Protection Requirements

- Data sensitif harus diklasifikasikan sebelum disimpan.
- Password tidak boleh disimpan plaintext.
- Dokumen dan data pribadi yang sensitif harus dilindungi dengan access control dan/atau enkripsi.
- Secret harus disimpan di environment variable atau secret manager, bukan source code.

7.5 Integrity and Non-Repudiation Requirements

- Perubahan data penting harus dapat diverifikasi.
- Digital signature digunakan untuk aksi yang membutuhkan bukti integritas dan non-repudiation.
- Audit log harus mencatat hasil aksi penting dan status verifikasi.

8. Prioritas Mitigasi

Urutan mitigasi yang disarankan:

1. Implementasi authentication dengan password hashing dan token/session aman.
2. Implementasi authorization berbasis role dan ownership.
3. Implementasi accounting/audit logging untuk aktivitas penting.
4. Implementasi enkripsi data sensitif yang dipilih.
5. Implementasi digital signature untuk aksi penting.
6. Penyusunan testing log untuk membuktikan kontrol keamanan berjalan.

9. Kesimpulan

Threat modeling menunjukkan bahwa risiko paling penting pada TUMBUH berkaitan dengan pengambilalihan akun, akses tidak sah, manipulasi data, kebocoran data pribadi, dan tidak adanya bukti aktivitas. Oleh karena itu, integrasi AAA security perlu menjadi prioritas utama sebelum sistem digunakan sebagai platform yang menangani data mahasiswa, perusahaan, dan proses lamaran.